本地端敏感資訊過濾機制　使用說明書

> 隊名：私密大師　|　版本：v0.1（2026-10）
>
> 把文字送給 AI 之前，先在你的電腦上把身分證、電話、姓名這些個資換成代號；AI 回覆回來時，再在你的電腦上換回來。**雲端 AI 從頭到尾只看到代號。**

目錄

1. 三十秒看懂
2. 我該用哪一個？
3. 安裝前準備
4. 啟動器：雙擊「啟動.bat」
5. 瀏覽器擴充（ChatGPT / Claude / Gemini）
6. AI Agent 防護（API Proxy）
7. 示範頁面
8. 認得哪些個資？
9. 常見問題與疑難排解
10. 已知限制
11. 你的資料存在哪裡？

系統怎麼運作的圖解見 流程圖與工作流。

---

1. 三十秒看懂

```
你輸入：　我的身分證是 A123456789，電話 0912-345-678，幫我寫請假信
                                ↓　在你的電腦上換掉
AI 收到：　我的身分證是 [TW_ID_1]，電話 [TW_PHONE_M_1]，幫我寫請假信
                                ↓　AI 照常回答
AI 回覆：　……申請人：[TW_ID_1]，聯絡電話：[TW_PHONE_M_1]
                                ↓　在你的電腦上換回來
你看到：　……申請人：A123456789，聯絡電話：0912-345-678
```

- **不用改變習慣**：照常複製貼上、照常用 AI。
- **AI 照樣幫得上忙**：它知道「這裡有一個身分證」，只是不知道號碼。
- **整個過程不經過任何第三方伺服器**，連我們自己的伺服器都沒有。

---

2. 我該用哪一個？

你平常怎麼用 AI	用這個	要裝什麼
在 ChatGPT / Claude / Gemini **網頁**上聊天	**瀏覽器擴充**（第 5 節）	Chrome
用 **AI 寫程式工具**（Aider、Cline、Codex、Claude Code…）	**API Proxy**（第 6 節）	Python 3.11
只是想先看看效果	**線上 Demo 網站**	什麼都不用裝

線上 Demo：**https://justingnps.github.io/tw-pii-filter/**（你在網頁上貼的文字只在你的瀏覽器裡運算，不會上傳。）

---

3. 安裝前準備

目前支援 **Windows 10 / 11**。

需要	什麼時候需要	下載
Google Chrome	用瀏覽器擴充	https://www.google.com/chrome/
Node.js（LTS 版）	自己建置瀏覽器擴充（拿到別人打包好的 zip 就不用）	https://nodejs.org/
Python 3.11	用 API Proxy 或示範頁面	https://www.python.org/downloads/

> **裝 Python 時一定要勾選「Add python.exe to PATH」**，否則啟動器找不到它。 請裝 3.10 ~ 3.12 之間的版本；3.13 以上目前不支援語意層。

取得程式：到 GitHub 下載 ZIP 並解壓縮，或用 `git clone`：

```
git clone https://github.com/JustinGNPS/tw-pii-filter.git
```

---

4. 啟動器：雙擊「啟動.bat」

專案資料夾最外層有一個 **`啟動.bat`**，雙擊它會出現選單：

```
============================================================
  本地端敏感資訊過濾機制 ── 私密大師
============================================================

  [1] 啟動 Proxy + 示範頁（試打台／即時監看／現況總覽）
      ─ 保護 AI coding agent，也是現場展示用的主畫面
  [2] 安裝或更新瀏覽器擴充
      ─ 讓 ChatGPT / Claude / Gemini 貼上時自動攔截，並在本機安全檢視回覆真值
  [3] 開啟線上 Demo 網站
  [4] 開啟使用說明書
  [Q] 離開

請選擇：
```

- **第一次雙擊**會先自動建立 Python 環境（約 1～3 分鐘），之後就不用等了。
- 輸入數字後按 Enter。

---

5. 瀏覽器擴充（ChatGPT / Claude / Gemini）

5.1 安裝

1. 雙擊 `啟動.bat`，選 `[2]`。它會自動建置擴充、打開檔案總管與 Chrome 的擴充功能頁面，並把資料夾路徑複製到剪貼簿。
2. 在 Chrome 的擴充功能頁面（`chrome://extensions`）：
3. 打開右上角的 **「開發人員模式」**
4. 按左上角的 **「載入未封裝項目」**
5. 選 `extension\dist` 資料夾（在選資料夾視窗上方的網址列按 **Ctrl+V** 貼上路徑最快）
6. 擴充清單出現「本地端敏感資訊過濾機制」就完成了。建議點工具列的拼圖圖示，把它釘選出來。

> **拿到的是 zip 檔？** 先解壓縮，然後直接做第 2 步，選解壓出來的資料夾即可，不需要 Node.js。
>
> **更新**：選 `[2]` 重新建置後，在擴充卡片上按 **「重新載入」**（圓形箭頭）。
>
> 為什麼要「開發人員模式」？因為目前還沒上架 Chrome 線上應用程式商店。 Chrome 的安全設計不允許任何程式替你按「載入」，所以這一步一定要自己點。

5.2 貼上時：確認面板

在 ChatGPT、Claude 或 Gemini 的輸入框照常按 **Ctrl+V**。如果內容有個資，會先跳出確認面板：

你的選擇	結果
遮蔽後貼上（按 Enter）	勾選的項目換成代號後貼上。可以取消勾選不想遮的項目
直接貼上原文	原文照貼。**你有最終決定權**，擴充不會強制攔你
不貼上（按 Esc）	什麼都不貼

- 沒有個資的內容會**直接貼上，不跳面板**，平常不會被打擾。
- 就算沒有身分證、電話，若內容組合起來能認出一個人（例如年齡 + 性別 + 地區 + 職稱），也會跳出面板提醒，並給出「35 歲 → 35-39 歲」這類泛化建議。
- 已經打在輸入框裡的文字：選取後**按右鍵 →「🛡 隱私處理後貼上」**。

5.3 AI 回覆：本機安全檢視

送出後，AI 網頁本身仍顯示代號；擴充會在右下角的**封閉本機檢視器**顯示還原結果。 真值不會寫回 ChatGPT、Claude 或 Gemini 的網頁文字節點。

右下角會出現一顆開關：

開關顯示	意思	按下去
🛡 本機檢視 N 處 · 點我關閉	封閉檢視器顯示真值；AI 頁面仍是代號	關閉本機檢視器
👁 AI 頁面顯示佔位符 · 點我本機還原	只看得到 AI 實際收到的代號	開啟本機檢視器

- 開關只在「這個對話有遮蔽過東西」時才出現。
- 若檢視器擋住網站按鈕，可按標題列右側的「移到左側 / 移到右側」切換位置。
- 輸入框裡的代號**不會**被還原。這是刻意的：輸入框是要送出去的內容，還原了就等於把真值送出去。
- AI 自己編出來、你從沒送出過的代號（例如 `[TW_ID_9]`）會原樣保留，**系統絕不猜測**。

5.4 小視窗（popup）

點工具列的擴充圖示，可以不開任何 AI 網站，直接貼一段文字看偵測結果與耗時。

小視窗下方的 **「要攔截哪些個資」** 可以逐項勾選（預設全部攔截）。 取消勾選的類型，在 AI 網頁貼上時會直接放行、不跳確認面板。設定只存在這台電腦。

---

6. AI Agent 防護（API Proxy）

給開發者用。Proxy 會擋在 AI 寫程式工具與雲端之間，工具讀到的檔案內容在送出前被遮蔽， AI 的回覆（包含它要寫進檔案的程式碼）在回到工具之前被還原。

6.1 設定上游（只需做一次）

第一次執行啟動器時，專案資料夾會自動產生一個 `.env` 檔。用記事本打開，填上兩行：

```
UPSTREAM_BASE_URL=https://api.openai.com/v1
UPSTREAM_API_KEY=你的金鑰
```

- 任何 **OpenAI 相容**的端點都可以（OpenAI、學校或公司的 LLM 閘道）。
- **真金鑰只放在這裡。** agent 那邊填假的（`dummy`）就好。
- `.env` 不會被上傳到 GitHub。
- 只用示範頁面的話，**不用填**。

6.2 啟動

雙擊 `啟動.bat`，選 `[1]`：

1. 問你要不要開啟**語意層**（認姓名、地址、職稱、公司）
2. 已安裝：直接選 Y 或 N。開啟後啟動多等約 10 秒
3. 未安裝：會問要不要現在安裝（約 1 GB，需要網路）。不裝也能用，只是認不出姓名地址
4. 啟動完成後會自動打開示範頁面，視窗裡會印出接下來要用的指令
5. **這個黑色視窗要一直開著**，關掉 proxy 就停了。要結束請按 **Ctrl+C**

6.3 讓 agent 走 proxy

另外開一個「命令提示字元」（cmd）視窗，依你用的工具設定：

工具	設定方式

Aider	`set OPENAI_API_BASE=http://127.0.0.1:8000/v1`
	`set OPENAI_API_KEY=dummy`
	然後執行 `aider`

Claude Code	`set ANTHROPIC_BASE_URL=http://127.0.0.1:8000`
	`set ANTHROPIC_API_KEY=dummy`
	然後執行 `claude`

Cline（VS Code）	設定 → API Provider 選 **OpenAI Compatible** Base URL：`http://127.0.0.1:8000/v1`，API Key：`dummy`
Continue（VS Code）	`~/.continue/config.yaml` 的 model 設 `provider: openai`、`apiBase: http://127.0.0.1:8000/v1`
Codex CLI	`config.toml` 自訂 provider（見下方範例）
OpenCode	`opencode.json` 自訂 provider（`@ai-sdk/openai-compatible`），baseURL 指向 `http://127.0.0.1:8000/v1`
Cursor	❌ **不支援**：Cursor 走自家伺服器，沒有地方可以改位址

Codex CLI 的 `config.toml` 範例：

```
model = "gpt-oss-120b"
model_provider = "local_proxy"

[model_providers.local_proxy]
name = "tw-pii-filter local proxy"
base_url = "http://127.0.0.1:8000/v1"
wire_api = "responses"
env_key = "TW_PII_DUMMY_KEY"   # 執行前先 set TW_PII_DUMMY_KEY=dummy
```

> Codex 預設用 ChatGPT 帳號登入，那條路攔不到。一定要用上面的「自訂 provider」模式。

6.4 ⚠️ 一定要確認流量真的有經過 proxy

設定沒生效時，不會有任何警告。 agent 照常運作，只是資料直接送去雲端了。

確認方法（任一個）：

- **看 proxy 視窗**：agent 開始工作後，應該出現一行 `第一個請求已抵達 proxy —— 流量確實有走這裡`
- **看示範頁「即時監看」分頁**：每個請求都會出現一列
- **打開** http://127.0.0.1:8000/healthz ：`traffic.requests` 大於 0 才有接上

6.5 proxy 視窗裡的訊息

訊息	意思
`已遮蔽：本輪新增 6 筆個資（TW_ID x3、TW_PHONE_M x3）`	這次請求裡有新的個資被換成代號（重複的不再印）
`還原 5 筆`	AI 的回覆裡有 5 個代號被換回真值
`（1 筆查無對照）`	AI 自己編了一個代號，原樣保留沒有猜
`組合風險 1.00（高）：ADDRESS、AGE、GENDER、POSITION`	沒被遮的資訊組合起來能認出一個人

6.6 選填設定

最簡單的方式：在示範頁的「設定」分頁直接勾選（見第 7 節），改了立即生效。 也可以寫在 `.env`（設定分頁存過的值優先於 `.env`）：

設定	預設	說明
`PII_RISK_REDUCTION_POLICY`	`off`	組合風險自動降階：`permissive` / `balanced` / `strict`（越後面遮得越多）
`PII_SKIP_TYPES`	`POSITION,COMPANY`	偵測到但不遮的類型（職稱、公司名預設不遮，但仍計入組合風險）
`PROXY_MAPPING_IDLE_TIMEOUT`	`1800`	閒置幾秒後清空對照表
`PII_IMAGE_POLICY`	`ocr`	圖片：`ocr` 本機辨識後遮蔽（失敗就移除）/ `remove` 直接移除 / `allow` 原圖送出、不檢查
`PII_DOCUMENT_POLICY`	`extract`	PDF：`extract` 優先抽文字；掃描版改走本機 OCR，再遮蔽（預設）/ `remove` 整份不送

6.7 agent 讀到的東西，哪些會被過濾？

agent 讀到的	處理方式
程式碼、`.env`、CSV、JSON、Markdown、設定檔等**文字檔**	✅ 遮蔽（主要保護對象）
你打的字、agent 的回覆、工具呼叫的參數	✅ 遮蔽
PDF（有文字層）	✅ 在你的電腦上轉成文字，再照常遮蔽。AI 讀得到內容，看不到個資；原始排版與圖片不保留
掃描版 PDF（只有圖）	✅ 在本機逐頁轉成圖片並 OCR，再照常遮蔽；任一頁辨識失敗就整份移除
圖片（截圖、照片）	✅ 預設在本機 OCR，只把遮蔽後文字交給 AI，原圖不送出；辨識失敗或信心不足時安全移除

移除時 agent 會繼續正常工作，不會整個卡住。

---

7. 示範頁面

啟動器選 `[1]` 後自動打開：http://127.0.0.1:8000/demo

分頁	做什麼
試打台	貼文字 → 看偵測結果、遮蔽版、組合風險、耗時；再按「還原」看假的 AI 回覆被換回真值。**完全不連網**
功能與流程	系統介紹與實測數據
即時監看	一邊跑 agent，一邊看 proxy 在背景遮了什麼、還原了什麼
瀏覽器擴充	擴充的說明
現況總覽	目前對照表有幾筆、快取命中率、流量統計
設定	逐項勾選要遮蔽哪些個資、開關語意層與組合風險、選擇圖片與 PDF 的處理方式。**改了立即生效**，並存在這台電腦，下次啟動自動套用（優先於 `.env`）。語意層開關只對這次執行有效

> 試打台用的是**自己的對照表**，不會影響 agent 正在用的那一份。

---

8. 認得哪些個資？

固定格式（規則層，永遠開啟，每次不到 3 毫秒）

類型	代號	例子	備註
身分證字號	`TW_ID`	A123456789	**驗證檢核碼**
統一編號	`TW_TAX`	12345675	**驗證檢核碼**
健保卡號	`TW_NHI`	000012345678	
手機號碼	`TW_PHONE_M`	0912-345-678	
市內電話	`TW_PHONE_L`	02-2345-6789	
電子郵件	`EMAIL`	someone@example.com	
信用卡號	`CREDIT_CARD`	4111 1111 1111 1111	**驗證 Luhn 檢核碼**
API 金鑰	`API_KEY`	sk-proj-…	

全形字（`Ａ１２３４５６７８９`）也認得。

語意（語意層，選配）

類型	代號	預設
姓名	`NAME`	遮
地址 / 地點	`ADDRESS`	遮
職稱	`POSITION`	偵測但不遮（計入組合風險）
公司名稱	`COMPANY`	偵測但不遮（計入組合風險）

> 語意層使用的是**可在本機離線執行的開源中文 NER 小模型**（約 389 MB），下載到電腦後不需要連網，文字不會被送去任何地方判斷。

組合風險

年齡、性別、地區、職稱單獨都不算個資，但**組合起來可能只剩幾個人**。系統會算出風險分數，並用內政部人口統計估算「符合這些條件的人最多有幾位」，再給出泛化建議。

---

9. 常見問題與疑難排解

安裝與啟動

Q：雙擊啟動.bat 說「找不到 Python 3.10 ~ 3.12」到 python.org 安裝 Python 3.11，安裝畫面第一頁要勾「Add python.exe to PATH」，裝完再雙擊一次。

Q：說「環境建立失敗」刪掉專案資料夾裡的 `.venv` 資料夾，再雙擊一次。仍失敗請截圖給開發者。

Q：說「埠 8000 被其他程式佔用」可能已經開了一個 proxy（那就直接用那個），或是其他程式佔用。可以改用別的埠：在 cmd 裡執行 `啟動.bat --port 8010`，agent 那邊的網址也要跟著改成 8010。

Q：選 [2] 說找不到 Node.js 安裝 Node.js LTS 版；或請組員用 `python tools\pack_extension.py` 打包 zip 給你。

瀏覽器擴充

Q：貼上時沒有跳出面板 1. 內容可能沒有個資，這是正常的（沒有個資就直接貼上） 2. 確認網站是 chatgpt.com、claude.ai 或 gemini.google.com（其他網站不攔） 3. 剛安裝或剛更新擴充的話，**重新整理 AI 網頁**

Q：我打的號碼為什麼沒被抓到？ 系統會驗檢核碼，**格式像、但檢核碼不對的號碼不會被當成個資**（這是刻意的，避免誤判）。在 AI 網頁貼上這類號碼時，擴充會在右下角跳一個小提示，例如「`0123456789` 格式像身分證，但檢核碼不正確」，並照原文貼上。在線上 Demo 或試打台輸入，也會告訴你沒抓到的原因：檢核碼不通過、位數不足，或需要語意層。

想測試效果，請用公開的測試值：身分證 `A123456789`、統編 `12345675`。

Q：AI 回覆在網頁裡仍顯示代號，怎麼看或複製真值？

- 這是刻意的安全設計：ChatGPT、Claude、Gemini 的網頁 DOM 從頭到尾都只保留代號， 避免網站腳本、分析工具或 session replay 重新讀到真值。因此網站自己的「複製」按鈕， 以及直接在 AI 回覆上用滑鼠選取後按 Ctrl+C，複製到的都會是代號版本
- 點右下角的「👁 AI 頁面顯示佔位符 · 點我本機還原」，在**本機還原檢視器**查看真值； 若要複製真值，請在這個檢視器裡選取文字後按 Ctrl+C
- 換了一個對話：每個對話的代號是獨立的，A 對話的 `[NAME_1]` 不會拿去還原 B 對話
- 在新對話貼上後若沒有送出、直接切到舊對話，該次暫存對照表會立即丟棄，之後開新對話不會沿用
- 超過 12 小時：對照表會自動過期
- AI 改寫了代號格式（例如寫成 `TW_ID_1` 少了方括號）：系統只認原本的格式，不猜
- 若右下角檢視器沒有展開，確認開關是否顯示「AI 頁面顯示佔位符 · 點我本機還原」並點一下

API Proxy

Q：agent 跑了但 proxy 視窗什麼都沒印 agent 沒有接到 proxy，**資料正直接送往雲端**。檢查 agent 的網址設定（第 6.3 節）， 並確認 `set` 指令是在**同一個 cmd 視窗**裡、在啟動 agent **之前**下的。

Q：agent 收到「上游 base URL 未設定」的錯誤 `.env` 的 `UPSTREAM_BASE_URL` 沒填，填好後關掉 proxy 視窗重開。

Q：agent 收到「連不上上游」或「逾時」 檢查網路、VPN，以及 `.env` 的網址是否正確。

Q：中文姓名、地址沒被遮 1. 啟動時是否選了開啟語意層 2. agent 讀檔時若用了不指定編碼的 PowerShell `type` 指令，中文會變亂碼，語意層就認不出來 （規則層的身分證、電話不受影響）。這取決於 agent 挑哪個指令，見已知限制

---

10. 已知限制

我們把做不到的事列清楚，不誇大：

限制	說明
Cursor 不支援	Cursor 走自家伺服器，沒有可攔截的位址
AI 網頁的複製與選取	網頁 DOM 只保留代號，因此網站的「複製」按鈕或直接選取 AI 回覆都只能取得代號；真值請從右下角的本機還原檢視器選取複製（見第 9 節）
擴充的語意層	擴充本身不內含大型模型；使用者可選擇連到同一台電腦的 `127.0.0.1` Proxy 執行語意辨識，因此進階辨識需要 Proxy 同時運作
Windows 主控台編碼	agent 用 PowerShell `type` 讀 UTF-8 檔案時中文會亂碼，語意層因此失效（規則層不受影響）
組合風險只是估計	人口數是「上限估計」，不是正式的匿名化保證
同一張身分證的全形與半形寫法	會拿到兩個不同代號（為了能還原成你原本的寫法）
圖片語意與版面	OCR 只取出印刷文字，不會把圖片場景、表格外觀或原始排版交給 AI；手寫、模糊、低信心內容會安全移除
還沒有安裝檔	擴充尚未上架 Chrome 商店；proxy 需要 Python 環境

---

11. 你的資料存在哪裡？

資料	存在哪	多久
你貼上、你送出的原文	**不儲存**	—
對照表（代號 ↔ 真值），擴充	你的 Chrome 本機儲存空間	12 小時後過期
對照表，proxy	proxy 的記憶體（**不寫入硬碟**）	閒置 30 分鐘清空；關掉 proxy 就消失
雲端 AI 的金鑰	你電腦上的 `.env`	由你管理
語意層模型	你的電腦	永久（下載一次，之後離線使用）
OCR 模型	你的電腦	隨套件安裝，辨識時不連外

沒有任何資料會送到我們或任何第三方的伺服器。 唯一對外的連線是你本來就要用的雲端 AI， 而它收到的是代號。

本專案以 MIT 授權釋出。原始碼：https://github.com/JustinGNPS/tw-pii-filter